Automating Response to Phishing with Cortex XSOAR

Security Operations Lab Writeup

Platform	Google Cloud Skills Boost (Lab developed in partnership with Palo Alto Networks)
Lab Title	Automating Response to Phishing with Cortex XSOAR
Reference	GSP951 – skills.google/focuses/30318
Tool Used	Cortex XSOAR (Security Orchestration, Automation and Response – SOAR)
Domain	SOC Operations / Incident Response / Security Automation
Date Completed	July 20, 2026

1. Overview

This lab focused on using Cortex XSOAR, a Security Orchestration, Automation, and Response (SOAR) platform, to investigate and remediate a simulated spear-phishing attack. The scenario involved an attacker who compromised the mail server of a fictional bank and used it to send phishing emails to executives at a partner organization during business hours. The objective was to practice a realistic SOC analyst workflow: triaging an incident, working inside a collaborative "War Room," executing a predefined incident response Work Plan/playbook, and generating a closing report.

The exercise reinforced core blue-team concepts including incident lifecycle management, playbook-driven automation, manual analyst intervention points, severity assessment, and reporting — all of which map directly to real-world SOC analyst and incident responder responsibilities.

Skills Demonstrated

- Incident triage and case management within a SOAR platform
- Interpreting and executing an automated Security playbook / Work Plan
- Manual phishing email analysis (headers, sender domain, embedded URLs)
- Identifying URL/hostname misrepresentation, a common phishing technique
- Incident severity assessment and escalation decision-making
- Cross-team collaboration workflows (War Room, personnel assignment)
- Generating and exporting incident response reports for stakeholders

2. Environment & Tools

- Cortex XSOAR (Free Edition) – SOAR platform for incident orchestration
- Pre-built "Email Phishing" response playbook
- Google Cloud-hosted lab sandbox environment

3. Step-by-Step Walkthrough

Step 1 – Reviewing the Incidents Dashboard

I started by logging into the Cortex XSOAR console and opening the Incidents dashboard. This is the analyst's central view of everything the platform has ingested — alerts, cases, and their current status — and is normally the first place a SOC analyst checks at the start of a shift.

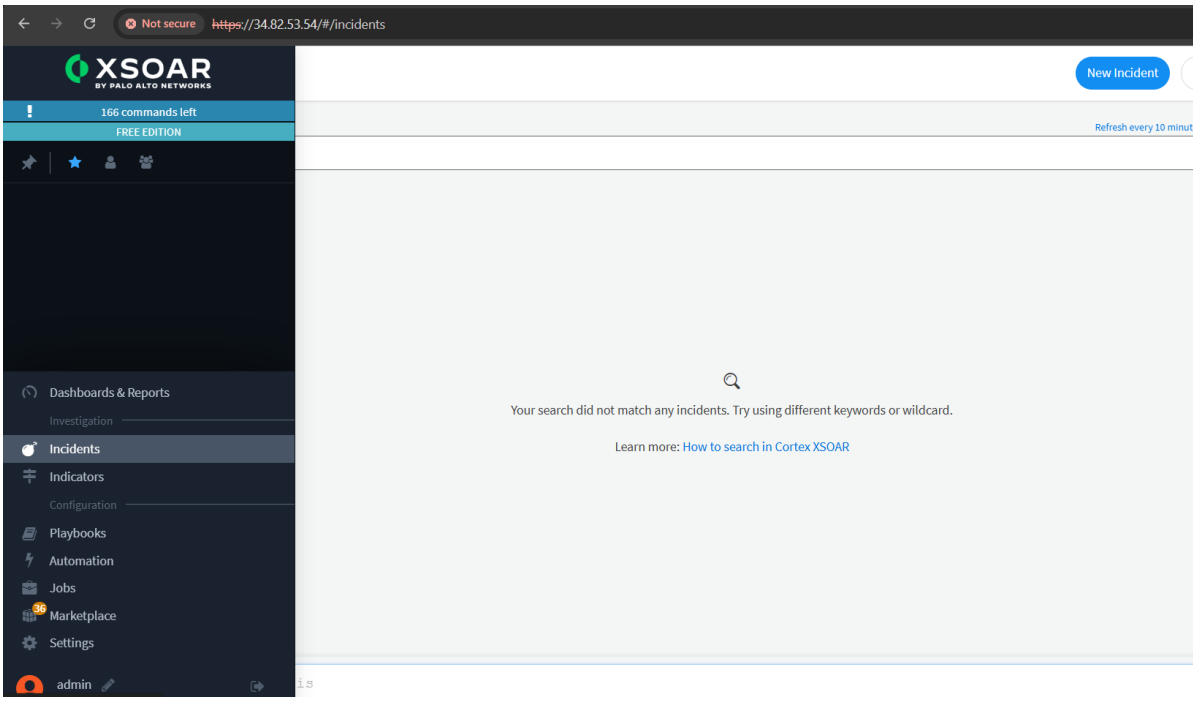


Figure 1 — The XSOAR Incidents dashboard, showing the main navigation (Dashboards, Incidents, Indicators, Playbooks, Automation) and the initial empty incident search.

Step 2 – Adjusting the Time Filter

By default the incident view only shows a recent time window, so no results were returned. I changed the "Created" date filter to All times to make sure historical and pre-seeded incidents in the lab environment were visible before creating a new one.

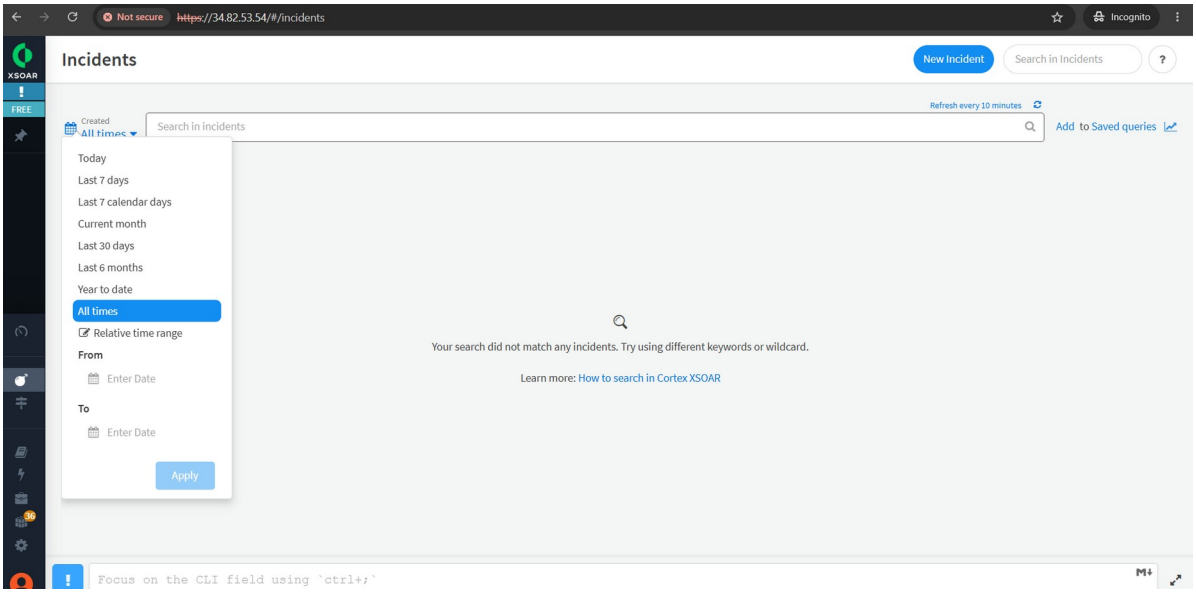


Figure 2 — Expanding the Created date-range filter and selecting All times so existing incidents are not hidden by a default time window.

Step 3 – Generating a New Phishing Incident

Next, I created a new incident to trigger the phishing response scenario. In the New Incident dialog I set the workshop scenario to Phishing Campaign and the Type to Scenario. XSOAR uses this to spin up a correlated

incident along with its associated Work Plan tasks, simulating how a real phishing alert would be ingested from an upstream detection source (in this case, Cortex XDR).

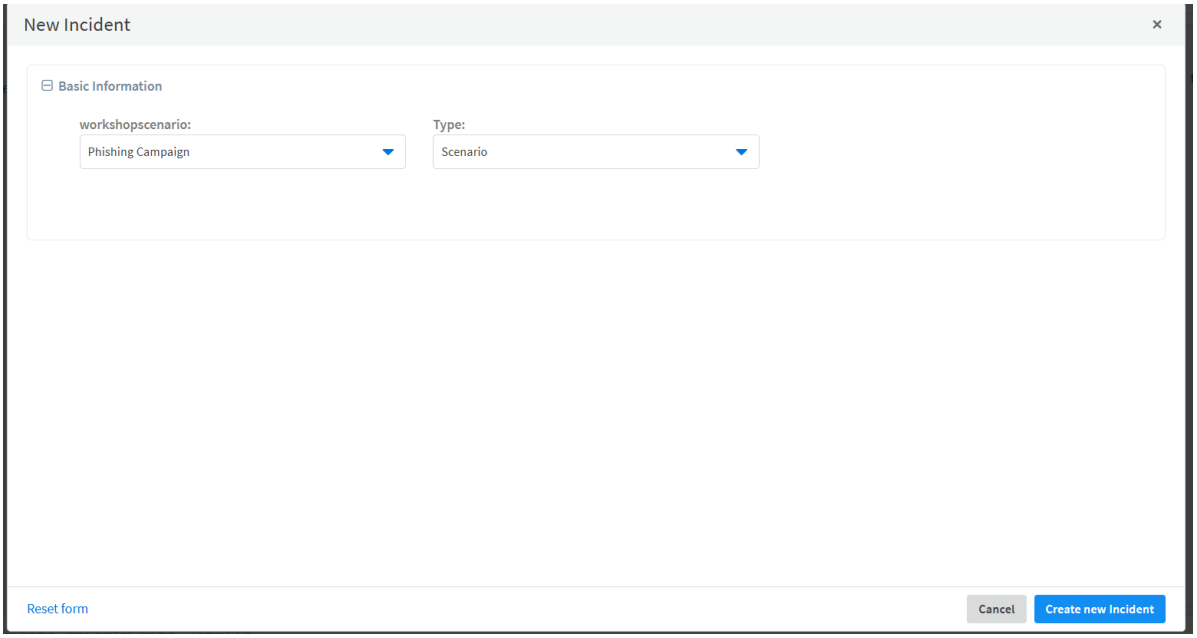


Figure 3 — The New Incident creation form, configured with the Phishing Campaign scenario before clicking Create New Incident.

Step 4 – Confirming Incident Creation

After a short processing delay (XSOAR correlating the incident with its Work Plan), the new incident appeared in the incident table as Incident #186, typed as Scenario with an Active status and the CreateDemoScenario playbook attached. This confirmed the phishing scenario had been successfully generated and queued for investigation.

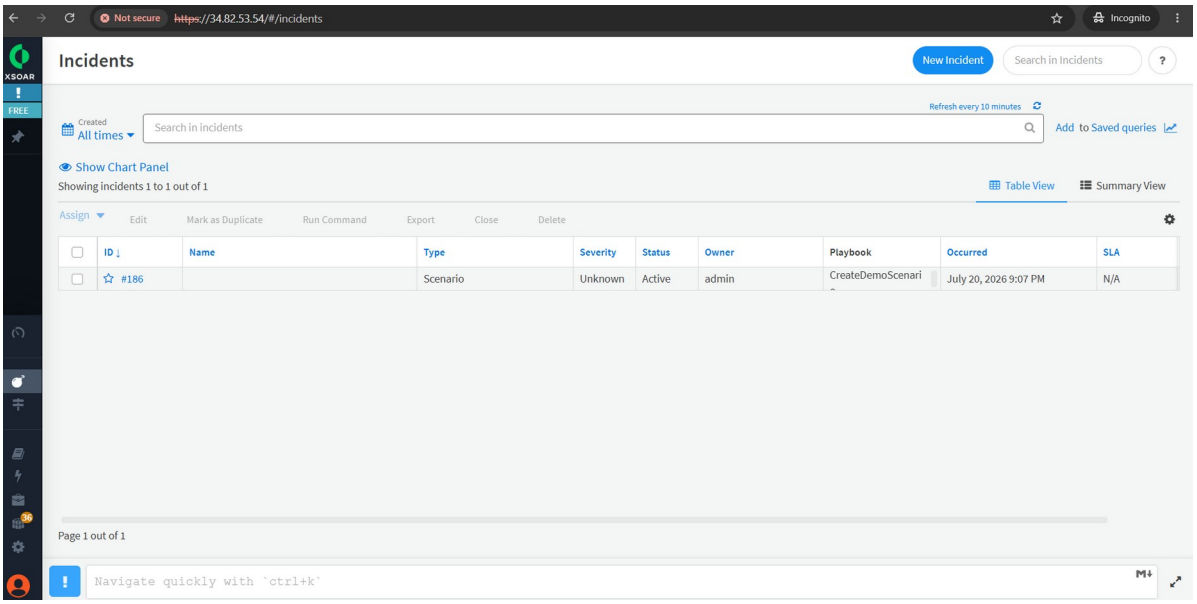


Figure 4 — Incident #186 listed in the Incidents table immediately after creation, with status Active and owner admin.

Step 5 – Inspecting the Incident's War Room

I opened the resulting phishing incident, #187 – "Possible Phishing – Jonas.Versailles@bordeauxbank.com," and reviewed the War Room, which is XSOAR's collaborative case workspace. It aggregates every automated action, analyst note, and system-generated field for the incident in one place, including severity (initially High), the assigned Email Phishing playbook, and metadata such as SLA and containment status — giving a full picture of the case before any manual action is taken.

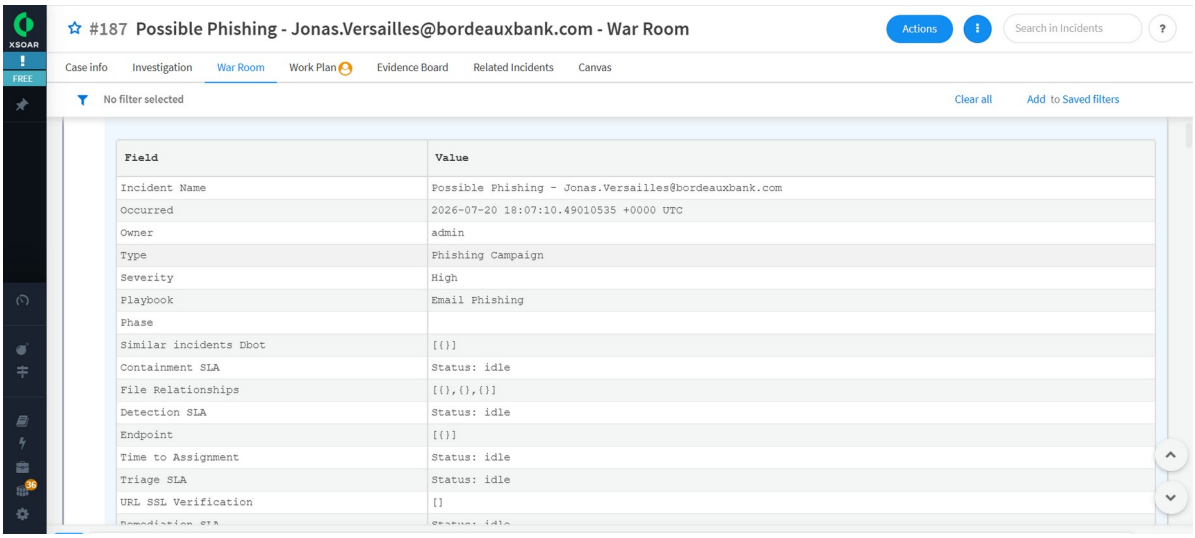


Figure 5 — The incident's War Room field/value summary, showing incident name, severity (High), owner, and the Email Phishing playbook assigned to the case.

Step 6 – Identifying the Manual Intervention Point

Scrolling through the War Room timeline, I saw that the playbook had already run several automated checks (e.g., CheckSenderDomainDistance) which did not flag anything conclusive. As a result, the playbook execution paused and handed control back to the analyst with task #31: "Manually inspect the email for anything suspicious." This reflects a realistic SOAR design pattern — automating the repetitive checks so the analyst's judgment is reserved for the ambiguous cases.

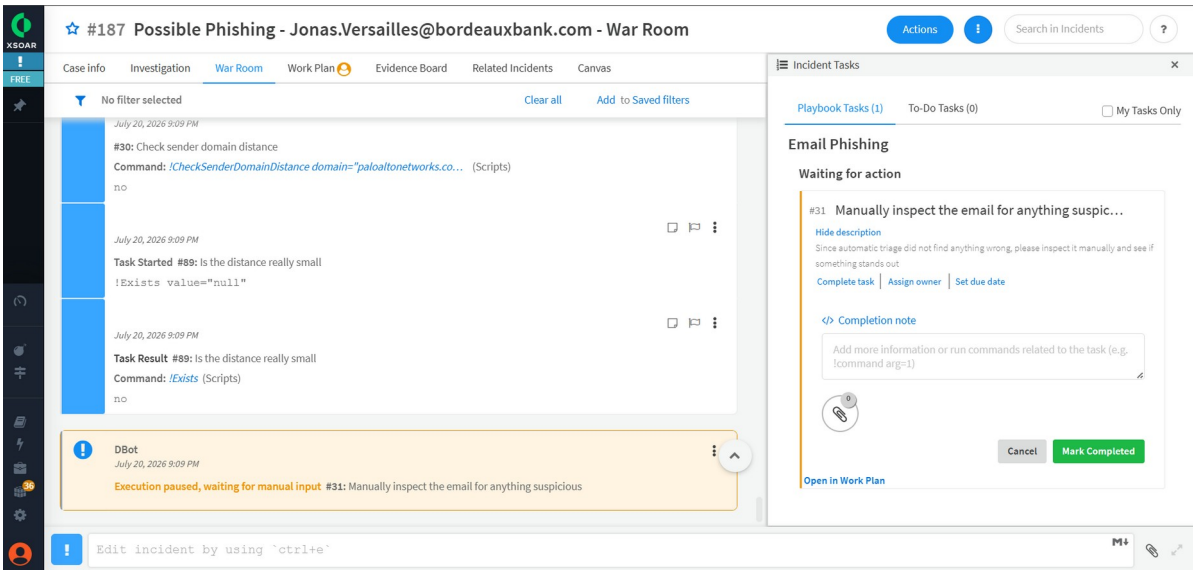


Figure 6 — DBot (the XSOAR automation engine) pausing playbook execution and requesting manual analyst input on task #31 after automated triage was inconclusive.

Step 7 – Opening the Work Plan

From the War Room, I opened the task directly in the Work Plan view, which renders the entire Email Phishing playbook as a visual flowchart. Green nodes represent completed automated steps (setting incident details, storing the sending account, extracting indicators, rasterizing the email, pulling the user's Active Directory info), giving a clear map of everything the platform had already handled before reaching the manual checkpoint.

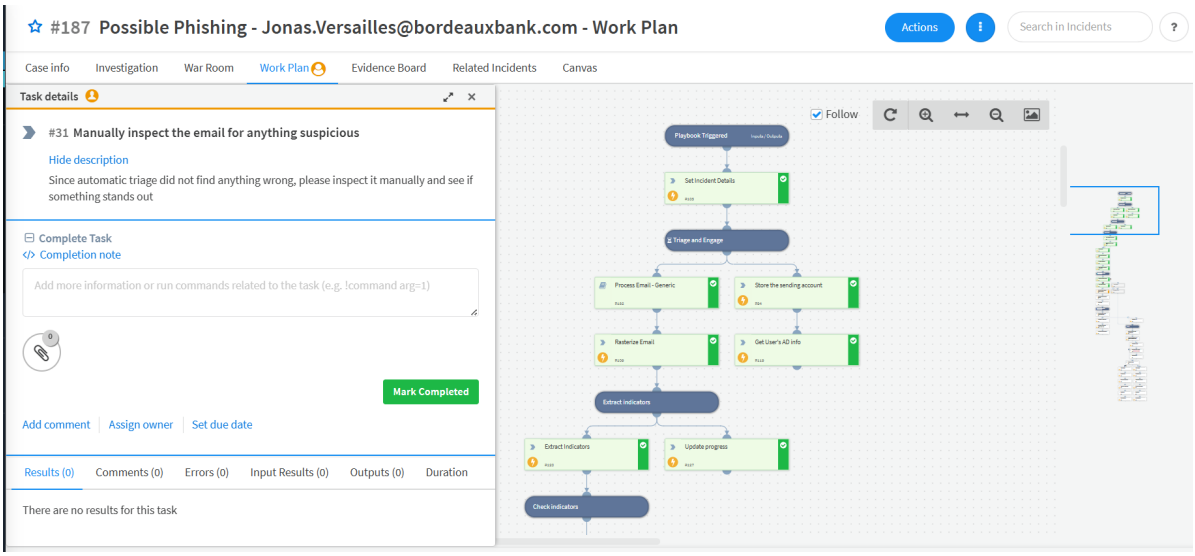


Figure 7 — The Work Plan flowchart view of the Email Phishing playbook, showing completed automated tasks (green) leading toward the indicator extraction stage.

Step 8 – Completing the Manual Email Inspection

Having reviewed the rasterized email image, sender domain, and embedded links from the Investigation tab, I found nothing indicating the email itself was malicious beyond the initial phishing report, so I marked task #31 ("Manually inspect the email for anything suspicious") as complete. This unblocked the playbook and let it advance to the next branch of the decision tree.

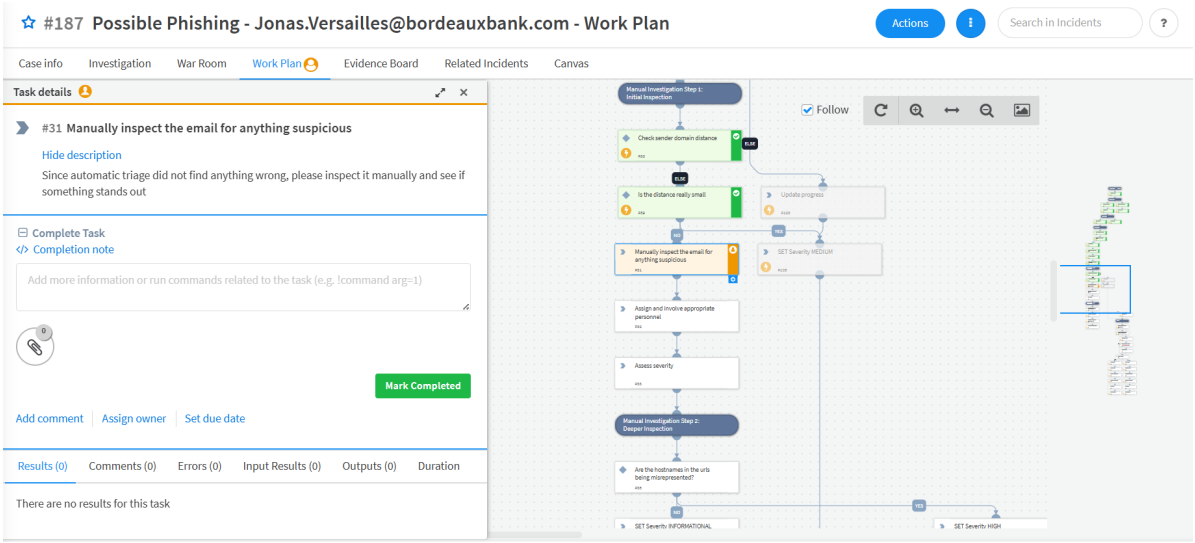


Figure 8 — Task #31 highlighted in the Work Plan graph with its details panel open, immediately before marking it complete to resume playbook execution.

Step 9 – Assigning Personnel to the Incident

With manual inspection complete, the playbook progressed to task #32, “Assign and involve appropriate personnel,” which exists to loop in a malware analyst or network engineer if the case escalates. Since no further specialist input was required for this incident, I marked the task complete, allowing the Work Plan to continue toward the severity assessment stage.

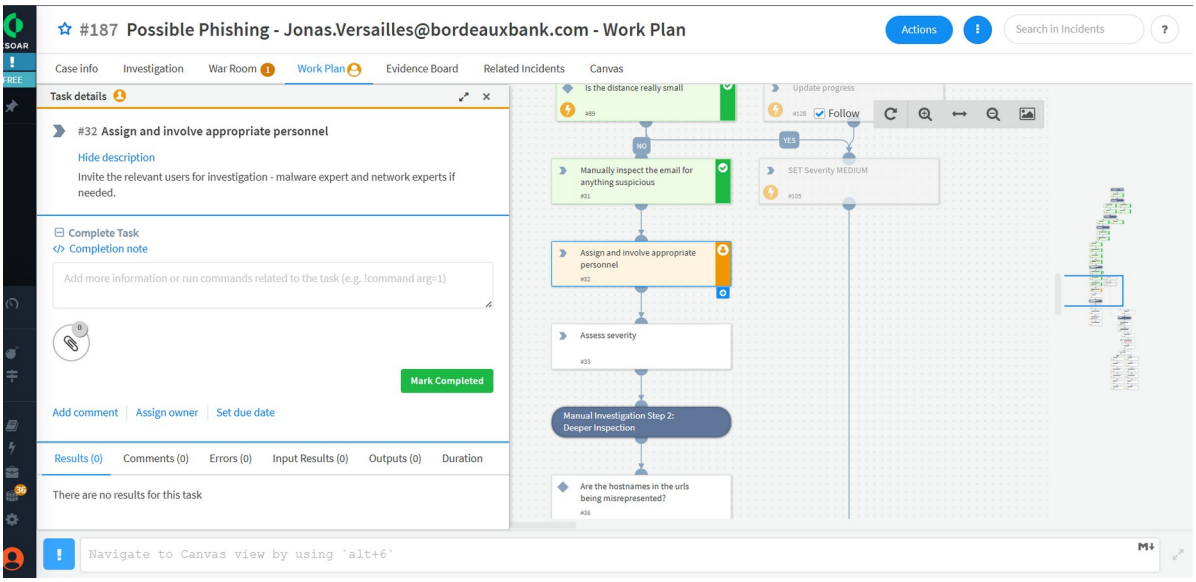


Figure 9 — Task #32 (Assign and involve appropriate personnel) shown in the Work Plan, representing the collaboration checkpoint before severity is assessed.

Step 10 – Assessing Incident Severity

The next task, #33 (“Assess severity”), required deciding whether to escalate the case based on the evidence gathered so far. This step is significant because the severity value chosen here determines which branch of the playbook runs next — informational, medium, or high/critical — which in turn dictates the remediation actions XSOAR will automatically trigger.

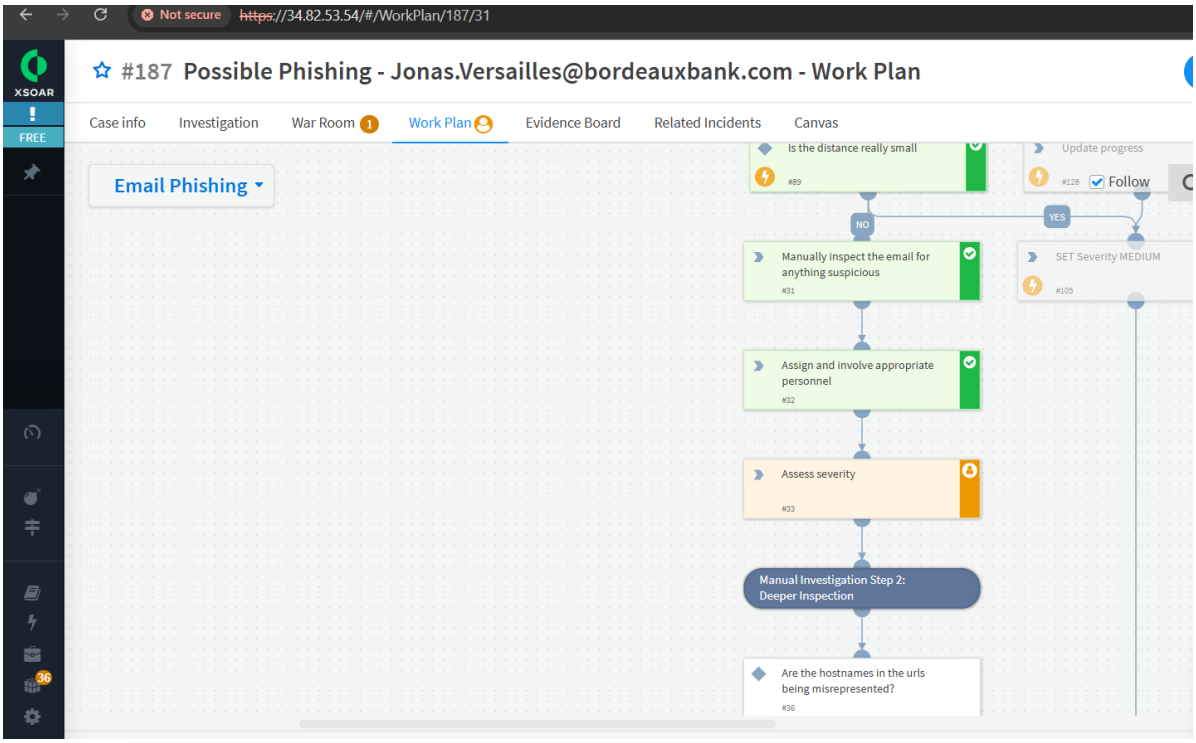


Figure 10 — The Work Plan graph highlighting the Assess severity task and its downstream branches for Manual Investigation Step 2 (checking for misrepresented hostnames in the email's URLs).

Step 11 – Completing the Playbook and Closing the Case

After completing the final manual checkpoint – verifying that the hostnames in the email's URLs were not being misrepresented (a common phishing technique used to disguise malicious links) – the remaining automated steps ran on their own: setting the final severity, notifying the targeted user that the email was safe, and closing the phishing investigation. The Work Plan view confirmed all tasks were done, and the incident was marked Closed.

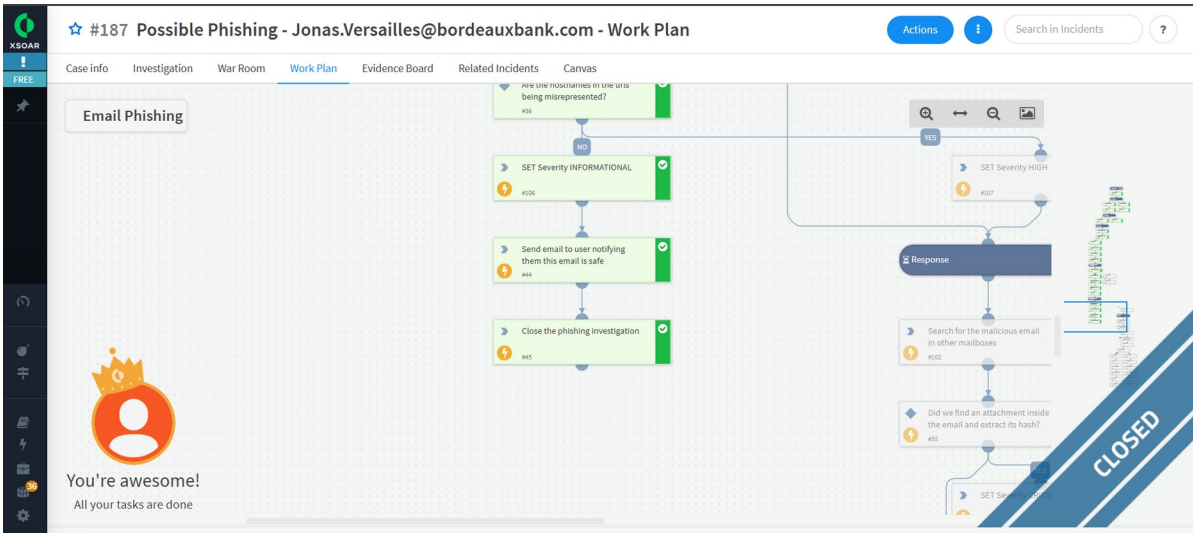


Figure 11 — The completed Work Plan with every task marked green and a CLOSED banner across the case, confirming the phishing investigation was fully remediated.

Step 12 – Reviewing Case Info and Generating the Report

Finally, I reviewed the Case Info tab to confirm the full resolution: severity had been downgraded to Informational, the case phase was Investigate, and the evidence board logged five items (extracted indicators, URL reputation, the outbound HTTP request, domain info, and the user notification). From here, XSOAR's Actions menu provides a Report option, which I used to generate and export a PDF summary of the incident for record-keeping and stakeholder communication — mirroring how a real SOC would document a closed case.

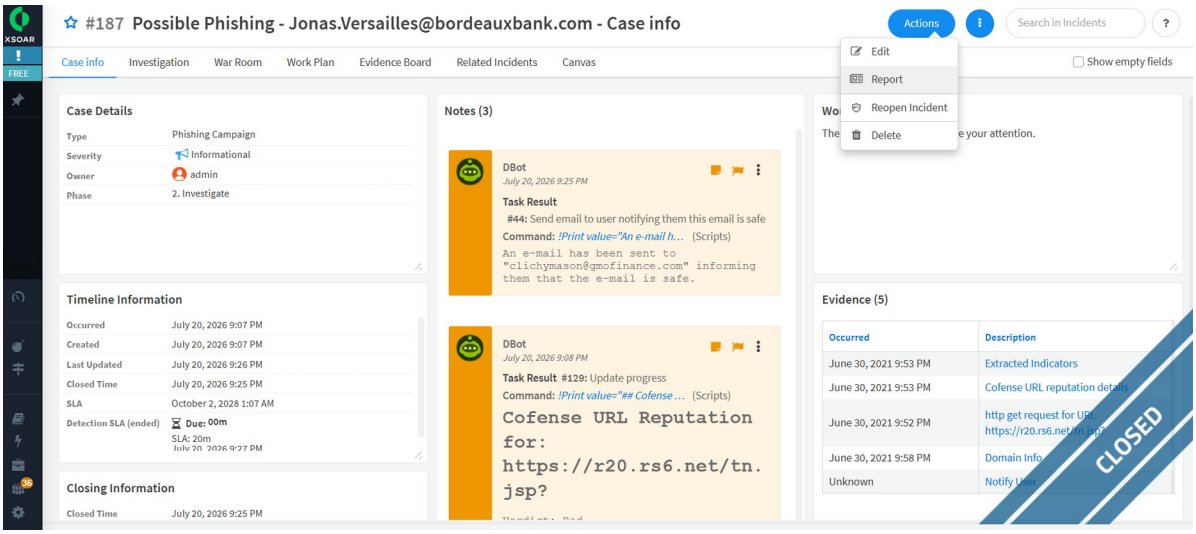


Figure 12 — The closed incident's Case Info tab with the Actions menu open, showing the Report option used to export a PDF summary of the investigation.

4. Results

- Successfully triaged and closed a simulated spear-phishing incident (#187) end-to-end using an automated SOAR playbook.
- Final incident severity: downgraded from an initial High rating to Informational after manual verification showed no malicious indicators.
- Completed all required manual checkpoints: email content review, personnel assignment, severity assessment, and URL/hostname verification.
- Verified the targeted user (Jonas.Versailles@bordeauxbank.com) was automatically notified that the reported email was safe.
- Exported a closing incident report (PDF) directly from the platform for documentation purposes.

5. Key Takeaways

This lab illustrated how SOAR platforms like Cortex XSOAR reduce phishing response time by automating repetitive triage steps (indicator extraction, domain distance checks, AD lookups) while still preserving clearly defined checkpoints where human judgment is required. Understanding how to read a playbook's Work Plan graph, resolve manual tasks, and interpret severity branching logic is directly transferable to real SOC analyst and incident responder roles, and reinforced my understanding of phishing indicators such as sender domain spoofing and URL/hostname misrepresentation.

Lab reference: "Automating Response to Phishing with Cortex XSOAR" (GSP951), Google Cloud Skills Boost, developed in partnership with Palo Alto Networks. Environment credentials and infrastructure were provided by the lab platform for training purposes only.